REDISEÑO DE ARQUITECTURA PARA EXPOSICIÓN PÚBLICA

Introducción y Contexto

El planteamiento inicial del Juego de Damas estaba diseñado para un entorno local bajo XAMPP, donde la confianza es implícita al compartir ambos jugadores la misma máquina. Sin embargo, al integrar el proyecto en la Sede Nube de AWS, surgió el requisito fundamental del TFG: exponer la aplicación directamente a internet para demostrar la capacidad de la infraestructura híbrida construida.

Este cambio no es meramente estético; implica pasar de un modelo de "confianza ciega" en el entorno local a un modelo de validación obligatoria en internet, donde cualquier usuario con la URL podría intentar interferir en partidas ajenas o realizar movimientos ilegítimos.

Desarrollo - Problemas Detectados y Rediseño

Al analizar el despliegue en la nube, se identificaron fallos críticos que funcionaban en local pero comprometían la seguridad y operatividad en AWS:

Desconexión de Servicios (Host 127.0.0.1)

En el entorno XAMPP, el archivo `DB.php` apuntaba a `127.0.0.1`, asumiendo que Apache y MySQL compartían servidor. En la infraestructura de AWS, esto provocaba un error de "Connection refused", ya que la base de datos reside en una instancia independiente (10.1.0.30).

Seguridad y Validación de Identidad

En local, la API (`api.php`) solo validaba la legalidad de los movimientos en el tablero, pero no la identidad de quien enviaba la petición. En internet, esto permitía que un atacante moviera fichas ajenas simplemente modificando el ID en la URL, el cual era además secuencial y fácil de enumerar.

Implementación

Identificación por Tokens SHA-256

Se eliminó el ID secuencial público. Ahora, el servidor genera un código aleatorio de 8 caracteres para la URL y tokens SHA-256 únicos por jugador (rojo/negro). El servidor utiliza `hash_equals()` para validar cada petición; si el token no es válido, se devuelve un error HTTP 403.

Arquitectura de Usuarios en MySQL

Se aplicó el principio de mínimo privilegio, separando los roles de acceso en la base de datos:

- damas_user: Solo permisos de `SELECT`, `INSERT` y `UPDATE` desde la IP del servidor web (10.1.0.85). No tiene permisos para alterar tablas (`DROP` o `ALTER`).
- damas_admin: Acceso total, pero restringido exclusivamente a través de la VPN.

El usuario root sigue existiendo, pero está totalmente bloqueado para accesos externos.

- Origen: Solo puede conectar desde `localhost` (dentro del propio servidor de base de datos).
- Función: Solo lo uso para tareas críticas de administración del motor MySQL o emergencias.
- Seguridad: No tiene acceso desde internet ni desde la VPN, lo que evita ataques directos de fuerza bruta a la cuenta principal.

Endurecimiento de Security Groups (AWS)

Antes de abrir el puerto 80 al público, se revisaron las reglas de entrada de las instancias:

- Servidor Web: Puerto 80 abierto a `0.0.0.0/0` para acceso público.
- Servidor BBDD: Puerto 3306 cerrado a internet. Solo acepta conexiones procedentes del Security Group del servidor web.

Comparativa

Componente	Antes (XAMPP Local)	Después (AWS Internet)
DB.php (Host)	`127.0.0.1`	`10.1.0.30`
Identificación	Sin validación	Tokens SHA-256 + Código aleatorio
ID Partida	Secuencial numérico	CHAR(8) aleatorio
MySQL Access	127.0.0.1 (local)	Solo desde 10.1.0.85 (privado)
Seguridad de Red	Firewall local desactivado	Security Groups restringidos

Conclusiones

Este nuevo planteamiento ha sido el motor de todos los avances posteriores de la Semana 3. La transición a internet obligó a profesionalizar el código, pasando de una aplicación de escritorio a una arquitectura web robusta. Ahora, el sistema no solo es funcional, sino que es seguro contra ataques de enumeración y accesos no autorizados a la base de datos, cumpliendo así con los estándares exigidos para el TFG.